

ĐỀ CƯƠNG CHI TIẾT

TÊN ĐỀ TÀI TIẾNG VIỆT: Triển khai hệ thống phát hiện và Phản Ứng Sự Cố Bảo Mật Dựa Trên Zero Trust Cho Hệ Thống Hướng Microservices Trong Môi Trường Multi-Cloud

TÊN ĐỀ TÀI TIẾNG ANH: Implementation Of A Zero Trust-Based Security Detection And Response System For Microservice Application In Multi-Cloud Environments

Cán bộ hướng dẫn: Đỗ Thị Phương Uyên

Thời gian thực hiện: Từ ngày 05/02/2026 đến ngày 30/05/2026

Sinh viên thực hiện:

Hoàng Bảo Phước - 23521231

Phạm Võ Khánh Hà - 23520414

Nội dung đề tài:

Tổng quan đề tài (sinh viên cần nêu rõ các đề tài, sản phẩm liên quan đã được nghiên cứu hoặc đã có trên thị trường trước thời điểm hiện tại và nêu thực trạng của chúng, để từ đó nêu bật được lý do thực hiện nghiên cứu trong KLTN này):

Trong kỷ nguyên chuyển đổi số đang diễn ra mạnh mẽ hiện nay, điện toán đám mây - Cloud Computing không chỉ còn là một sự lựa chọn mà đã trở thành nền tảng công nghệ xu hướng chủ đạo để phát triển của nhiều doanh nghiệp nhằm tối ưu chi phí và tối đa hóa hiệu năng dịch vụ. Đặc biệt, ngành Tài chính - Ngân hàng đã và đang chứng kiến sự dịch chuyển mạnh mẽ sang mô hình Multi-Cloud. Đây là chiến lược then chốt giúp các ngân hàng giải quyết bài toán song hành: duy trì sự ổn định, bảo mật tuyệt đối cho hệ thống Core Banking và dữ liệu nhạy cảm trên hạ tầng On-premises hoặc Private Cloud, đồng thời tận dụng khả năng mở rộng linh hoạt của Public Cloud để phát triển các dịch vụ ngân hàng số hiện đại. Theo Gartner (2024), hơn 85% doanh nghiệp sử dụng ít nhất hai nhà cung cấp cloud khác nhau. Xu hướng sử dụng dịch vụ triển khai trên hạ tầng đa Multi-Cloud ngày càng phổ biến, cho phép

tận dụng điểm mạnh của nhiều nhà cung cấp dịch vụ khác nhau giúp doanh nghiệp linh hoạt trong điều phối tài nguyên, đồng thời tránh vendor lock-in.

Tuy nhiên, sự phức tạp của cấu trúc hạ tầng này cũng đã tạo ra những điểm mù về bảo mật. Các cuộc tấn công hiện đại không chỉ dừng lại ở lateral movement mà còn mở rộng sang tấn công chuỗi cung ứng phần mềm (software supply chain attacks) và khai thác định danh số. Các mô hình bảo mật truyền thống đã nhanh chóng lỗi thời và bộc lộ các lỗ hổng nghiêm trọng, mô hình hạ tầng dựa trên network perimeter và implicit trust đã không còn hiệu quả, dễ dẫn đến nguy cơ bị tấn công lateral movement như SolarWinds (2020), Colonial Pipeline (2021). Thiếu sự thống nhất trong chính sách và giám sát bảo mật giữa các miền cloud khiến thời gian phát hiện vi phạm (MTTD) cao hơn trung bình 27% so với môi trường đơn lẻ (IBM, 2023).

Hiện nay, mặc dù thị trường đã có các giải pháp Zero Trust và SASE như Cloudflare One, Zscaler hay Palo Alto Prisma Access, nhưng các doanh nghiệp vận hành Multi-Cloud vẫn đối mặt với thách thức về quyền tự chủ công nghệ và chi phí bản quyền rất cao. Hơn nữa, việc tích hợp dữ liệu bảo mật giữa các nền tảng Public và Private Cloud thường bị rời rạc, gây khó khăn cho việc phản ứng đồng bộ.

Từ đó, đề tài này triển khai một hệ thống phòng thủ chủ động dựa trên kiến trúc Zero Trust (ZTA). Hệ thống sử dụng SPIRE để cấp phát và quản lý định danh workload, Envoy Proxy để kiểm soát luồng tin và Keycloak để xác thực. Dù kiến trúc Zero Trust bảo vệ rất tốt lớp định danh, nhưng nếu thiếu một hệ thống giám sát tập trung và phản ứng tự động, việc phát hiện các hành vi xâm nhập hoặc lỗi cấu hình vẫn phụ thuộc nhiều vào con người, dẫn đến độ trễ lớn trong xử lý sự cố. Vậy nên, việc thiết lập hệ thống triển khai hệ thống SIEM/SOAR dựa trên ELK, Wazuh và OpenSearch để thu thập và phân tích log từ các thành phần Zero Trust nhằm tự động hóa quy trình phân tích, thực thi các kịch bản phản ứng Playbooks khi phát hiện dấu hiệu xâm nhập hoặc lỗi cấu hình nghiêm trọng.

Mục tiêu của đề tài (Nêu cụ thể mục tiêu của KLTN, đặc biệt phải nêu được mục tiêu cải tiến sẽ là gì so với thực trạng nêu trong phần tổng quan đề tài):

1. Mục tiêu tổng quát

- Nghiên cứu và triển khai mô hình phòng thủ chủ động dựa trên kiến trúc Zero Trust tích hợp hệ thống SIEM/SOAR hỗ trợ AI trên hạ tầng Multi-Cloud. Mục tiêu trọng tâm là thiết lập một cơ chế quản trị định danh nhất quán, tự động hóa quy trình giám sát và phản ứng sự cố để thay thế cho các phương thức thủ công, từ đó tối ưu hóa các chỉ số an ninh (MTTD, MTTR) và đảm bảo tính phục hồi cho các dịch vụ tài chính nhạy cảm.

2. Mục tiêu cụ thể:

- a. Thiết lập nền tảng định danh Zero Trust phi tập trung - Identity-based Security
 - Triển khai cơ chế định danh số dựa trên tiêu chuẩn SPIFFE/SPIRE để cấp phát danh tính (SVID) cho các workload chạy trên hạ tầng Multi-Cloud (AWS và OpenStack). Mục tiêu là loại bỏ hoàn toàn sự tin tưởng chỉ dựa trên địa chỉ IP, thay thế bằng xác thực dựa trên định danh động.
- b. Thực thi kiểm soát truy cập thích ứng - Adaptive Access Control
 - Sử dụng Envoy Proxy làm điểm thực thi chính sách (Policy Enforcement Point - PEP) kết hợp với Keycloak. Mục tiêu là đảm bảo mọi yêu cầu truy cập từ bên ngoài hay từ trong nội bộ đều phải được xác thực, ủy quyền và mã hóa (mTLS) trước khi thiết lập kết nối để đảm bảo tính toàn vẹn của dữ liệu trong môi trường microservice phân tán.
- c. Xây dựng khả năng giám sát thông minh và phản ứng liên tục cho mô hình Zero Trust - Continuous AI-driven Observability
 - Tích hợp SIEM trên hạ tầng AWS để thu thập và chuẩn hóa mọi dữ liệu định danh từ SPIRE, luồng tin từ Envoy và các log xác thực từ Keycloak. Mục tiêu là sử dụng các mô hình AI (LSTM, Isolation Forest) kết hợp với cơ chế RAG để nhận diện hành vi bất thường và cung cấp Threat Intelligence tạo ra một vòng lặp phản hồi bảo mật (security feedback loop) giúp hệ thống Zero Trust không chỉ kiểm soát truy cập mà còn có khả năng phát hiện hành vi bất thường và hỗ trợ điều chỉnh chính sách bảo mật theo ngữ cảnh.
- d. Tự động hóa quy trình phản ứng để duy trì trạng thái Zero Trust - Automated Incident Response
 - Thiết kế và triển khai các kịch bản phản ứng tự động (Playbooks) thông qua SOAR (TheHive, n8n) nhằm tự động xử lý tức thời các vi phạm chính sách Zero Trust (chẳng hạn như cô lập workload khi hệ thống phát hiện lưu lượng bất thường và cập nhật chính sách truy cập thông qua Envoy,...). Mục tiêu là giảm thiểu tối đa thời gian tồn tại của mối đe dọa (Dwell Time) và tối ưu hóa khả năng tự động phòng thủ của hệ thống.

Phương pháp thực hiện (Nêu tổng quan phương pháp thực hiện):

Thiết kế theo nguyên tắc Security by Design kết hợp với Threat Modeling. Nhóm áp dụng phương pháp STRIDE để phân tích toàn bộ attack surface của hệ thống tài chính microservices, từ đó xác định các điểm kiểm soát bảo mật cần thiết và thiết kế kiến trúc tương ứng. Kiến trúc được mô hình hóa bằng sơ đồ luồng dữ liệu Data Flow Diagram theo chuẩn OWASP Threat Dragon trước khi triển khai.

Toàn bộ hạ tầng được triển khai theo phương pháp Infrastructure as Code (IaC): Terraform cho provisioning tài nguyên OpenStack và AWS (VM, network, security groups), Ansible cho configuration management (cài đặt, cấu hình). Phương pháp này đảm bảo linh hoạt, môi trường có thể tái tạo hoàn toàn dễ dàng, ổn định, không có sự khác biệt giữa các lần triển khai, và khả năng drift detection, phát hiện thay đổi không mong muốn trên hạ tầng thực tế so với code.

Các nội dung chính và giới hạn của đề tài (Nêu nội dung thực hiện và phương pháp dự kiến để đánh giá hệ thống, ví dụ, nếu KLTN có chạy demo thì hệ thống demo sẽ như thế nào):

1. Nội dung thực hiện

- a. Mô hình hóa và triển khai hệ thống tài chính microservices trên Multi-Cloud
 - Xây dựng và triển khai financial microservices Container dựa trên K3s, phân bố theo phân loại dữ liệu (Data Classification):
 - Trên AWS K3s cluster gồm API Gateway Service, Payment Processing Service, Fraud Detection Service, và Notification Service;
 - Trên OpenStack K3s cluster gồm Core Banking API, Account Service, Transaction Service.
 - Mỗi service được cấu hình với REST API đủ để tạo ra log traffic thực tế và mô phỏng các attack vectors trong domain tài chính. Toàn bộ service-to-service communication đi qua Envoy Proxy được kiểm soát bởi OPA và bảo vệ bằng mTLS với SPIFFE/SPIRE identity.
- b. Log Collection Pipeline với Wazuh Agent và Filebeat
 - Hệ thống triển khai Wazuh Agent trên các node quan trọng như Auth Portal, AWS Gateway, OS Gateway, các K3s Master và Identity Server để thu thập dữ liệu giám sát bảo mật. Wazuh thực hiện File Integrity Monitoring trên các tệp cấu hình Zero Trust và thu thập các loại log như system logs, authentication logs, container logs và audit logs nhằm phát hiện các mối đe dọa như brute force login, port scanning, privilege escalation và các API call đáng ngờ.
 - Bên cạnh đó, Filebeat được sử dụng để thu thập Envoy access logs ở định dạng JSON và gửi đến Logstash để xử lý và bổ sung thông tin trước khi lưu vào Elasticsearch và truyền qua Kafka. Ngoài việc giám sát log hệ thống, mỗi financial microservice còn triển khai một Prometheus exporter tùy chỉnh để thu thập các chỉ số bảo mật ở mức nghiệp vụ, như tốc độ giao dịch theo người dùng, tỷ lệ đăng nhập thất bại và tần suất truy cập API. Những dữ liệu này giúp hệ thống theo dõi hành vi sử dụng dịch vụ và phát hiện các hoạt động bất thường như gian lận giao dịch, brute force hoặc lạm dụng API.

c. SIEM Engine với Elasticsearch và Wazuh Correlation

- Hệ thống Elasticsearch được cấu hình với nhiều index riêng biệt để lưu trữ các loại dữ liệu bảo mật trong kiến trúc Zero Trust, bao gồm zta-envoy-logs, zta-wazuh-alerts, zta-opa-decision, zta-spire-events và zta-financial-metrics. Đồng thời, Index Lifecycle Management (ILM) được sử dụng để tự động quản lý vòng đời dữ liệu qua các giai đoạn Hot, Warm, Cold và Delete, giúp tối ưu chi phí lưu trữ và đảm bảo thời gian lưu log đáp ứng yêu cầu tuân thủ như PCI-DSS.
- Ngoài ra, hệ thống phát triển các Wazuh decoder và correlation rules tùy chỉnh để phát hiện các mối đe dọa trong môi trường Zero Trust tài chính, như giả mạo JWT token, brute-force phân tán từ nhiều IP, và các hành vi di chuyển ngang giữa các workload. Hệ thống cũng xây dựng các dashboard trên Kibana gồm ZTA Security Overview, Identity & Access Map, Threat Intelligence Feed và mTLS & Workload Health để trực quan hóa trạng thái bảo mật và theo dõi hoạt động của các dịch vụ trong hệ thống.

d. Realtime Streaming với Apache Kafka và OpenSearch Anomaly Detection

- Hệ thống sử dụng Apache Kafka để thu thập và truyền log theo thời gian thực với các topic chính: zta.raw-logs, zta.wazuh-alerts và zta.ai-detections. Kafka Connect được cấu hình để tự động gửi log vào OpenSearch, giúp dữ liệu được cập nhật nhanh nhất đến hệ thống phân tích.
- Trên OpenSearch, hệ thống triển khai các Anomaly Detectors sử dụng thuật toán Random Cut Forest để phát hiện hành vi bất thường như tăng đột biến số lượng request, nhiều lần đăng nhập bị từ chối, lưu lượng bất thường giữa các cloud và tốc độ giao dịch tài chính bất thường. Các detector sẽ tự học hành vi bình thường của hệ thống trong tuần đầu và tự điều chỉnh ngưỡng cảnh báo khi hệ thống thay đổi.

e. AI Detection Engine: ML Models, RAG Pipeline, và MCP Integration

- Hệ thống AI phát hiện tấn công gồm ba phần.
 - Thứ nhất là hai mô hình machine learning (Isolation Forest và LSTM Autoencoder) dùng để phát hiện hành vi bất thường trong log và dữ liệu giao dịch. Các mô hình này có thể được tận dụng để huấn luyện lại mỗi tuần dựa trên dữ liệu 30 ngày gần nhất.
 - Thứ hai là RAG pipeline sử dụng cơ sở dữ liệu vector chứa thông tin từ MITRE ATT&CK, CVE và các báo cáo tấn công tài chính. Khi có cảnh báo, hệ thống sẽ tìm các tài liệu liên quan để hỗ trợ AI phân tích sự kiện.
 - Thứ ba là MCP integration, cho phép AI truy cập trực tiếp dữ liệu từ Elasticsearch, Wazuh, SPIRE và TheHive để phân tích sự kiện bảo mật theo thời gian thực.

f. SOAR Platform: TheHive, Cortex Responders, và AI Playbook Engine

- Hệ thống SOAR sử dụng TheHive để quản lý các sự cố bảo mật. Khi có cảnh báo, hệ thống tự động tạo case và phân loại mức độ nghiêm trọng. Các cảnh báo giống nhau trong một khoảng thời gian sẽ được nhóm lại để dễ theo dõi.
- Hệ thống còn có AI Playbook Engine giúp tự động tạo quy trình xử lý sự cố gồm bốn bước: contain, investigate, eradicate và recover. Ngoài ra, một số hành động tự động được triển khai như chặn IP tấn công, thu hồi phiên đăng nhập, cô lập node khỏi mạng hoặc cập nhật chính sách truy cập.

g. Human-in-the-Loop kiểm soát quy trình ra quyết định

- Để đảm bảo các hành động quan trọng được kiểm soát, hệ thống sử dụng n8n và Slack để thực hiện cơ chế human-in-the-loop. Khi một hành động cần phê duyệt, hệ thống sẽ gửi thông báo tới Slack để chuyên gia bảo mật Approve hoặc Reject.
- Mọi quyết định đều được ghi lại cùng thời gian và người phê duyệt trong hệ thống log nhằm phục vụ kiểm toán và đáp ứng các yêu cầu tuân thủ như PCI-DSS.

2. Phương pháp đánh giá

- Kiểm thử được thực hiện theo ba phương pháp song song:
 - a. Functional testing – chạy 20 kịch bản tấn công được xây dựng theo MITRE ATT&CK for Cloud, mỗi kịch bản có kế hoạch và thiết kế Expected Outcome rõ ràng và Acceptance Criteria được định nghĩa trước;
 - b. Performance testing – sử dụng Apache JMeter để mô phỏng tải 100 transactions/giây và đo tác động của các lớp bảo mật lên throughput;
 - c. Quantitative evaluation – thu thập và phân tích 10 metrics quan trọng (MTTD, MTTR, FPR, FNR, Security Overhead...) để so sánh với baseline và mục tiêu, kết quả mong muốn đã được đề ra.

3. Giới hạn của đề tài

- Kafka trong hệ thống chỉ được triển khai với một broker do giới hạn tài nguyên lab. Nếu node Kafka hoặc OpenSearch gặp sự cố, pipeline streaming log theo thời gian thực sẽ tạm dừng và các cảnh báo AI sẽ không được tạo trong thời gian đó. Trong môi trường production, cần triển khai Kafka cluster với nhiều broker và cơ chế replication để đảm bảo tính sẵn sàng cao.
- Các financial microservices trong hệ thống chỉ được xây dựng để tạo log và mô phỏng tấn công cơ bản. Chưa triển khai được đầy đủ các chức năng phức tạp của hệ thống ngân hàng thực tế như đa tiền tệ, lãi suất, RTGS hay tích hợp với mạng SWIFT. Do đó một số loại tấn công đặc thù của hệ thống core banking chưa được kiểm thử đầy đủ.

- Các kịch bản kiểm thử trong đề tài đều là các cuộc tấn công ngắn hạn. Hệ thống chưa được đánh giá với các Advanced Persistent Threat (APT) kéo dài nhiều tuần hoặc nhiều tháng, nơi kẻ tấn công hoạt động chậm để tránh bị phát hiện. Việc kiểm thử APT đòi hỏi các bài kiểm thử red-team dài hạn vượt quá phạm vi của đề tài.
- Mặc dù hệ thống lưu trữ log đáp ứng yêu cầu thời gian lưu trữ của PCI-DSS, hiện tại chưa có chức năng tự động tạo báo cáo kiểm toán theo định dạng chuẩn của PCI-DSS. Việc phát triển module compliance reporting sẽ là hướng mở rộng quan trọng trong các nghiên cứu tiếp theo.

Kế hoạch thực hiện: *(Mô tả kế hoạch làm việc và phân công công việc cho từng sinh viên tham gia)*

1. Kế hoạch thực hiện

- Kế hoạch làm việc triển khai và đánh giá chia trong 5 giai đoạn quan trọng.

Giai đoạn	Thời gian	Mục tiêu chính	Kết quả đạt được
Giai đoạn 1 – Research & Thiết kế kiến trúc	Từ 05/03 đến 18/03	Nghiên cứu tài liệu Zero Trust, SIEM/SOAR, PCI-DSS, MITRE ATT&CK for Cloud. Phân tích các giải pháp SIEM hiện có và xác định mô hình kiến trúc cho hệ thống. Thiết kế kiến trúc tổng thể và mô hình threat modeling.	Architecture Design Document, Threat Model (STRIDE), Project Plan.
Giai đoạn 2 – Xây dựng hạ tầng và SIEM Core	Từ 19/03 đến 08/04	Triển khai hạ tầng OpenStack, K3s clusters và các node hệ thống. Cài đặt Wazuh, ELK Stack, Kafka và cấu hình pipeline thu thập log. Xây dựng dashboards và rule phát hiện tấn công.	Hệ thống SIEM hoạt động, log pipeline end-to-end, dashboards giám sát.
Giai đoạn 3 – AI Detection Engine	Từ 09/04 đến 29/04	Thu thập dữ liệu huấn luyện, xây dựng các mô hình phát hiện bất thường và pipeline RAG. Phát triển AI engine để phân tích sự kiện bảo mật và tạo cảnh báo nâng cao.	AI Detection Engine hoạt động, RAG pipeline, đánh giá model.
Giai đoạn 4 – SOAR và Human-in-the-Loop	Từ 30/04 đến 13/05	Triển khai nền tảng SOAR với TheHive và Cortex. Xây dựng AI Playbook Engine và workflow Human-in-the-Loop để phê duyệt hành động phản ứng sự cố.	SOAR pipeline hoạt động, AI Playbook, HITL workflow.
Giai đoạn 5 – Kiểm thử và hoàn thiện báo cáo	Từ 14/05 đến 30/05	Thiết kế kịch bản tấn công, đánh giá hiệu quả hệ thống và đo lường các chỉ số. Hoàn thiện báo cáo đồ án, slide và demo.	Final Report, Slide thuyết trình, Demo video.

2. Phân công công việc

- Mỗi giai đoạn gồm nhiều tuần cập nhật tiến độ, liên tục review và họp định kỳ để đánh giá hiệu quả triển khai và điều chỉnh kế hoạch nếu cần.

STT	Hạng mục công việc	Thực hiện	Thời gian
1	Nghiên cứu tài liệu Zero Trust, PCI-DSS, MITRE ATT&CK	Khánh Hà	05/03 – 10/03
2	Phân tích các giải pháp SIEM/SOAR (Splunk, QRadar, Sentinel, ELK, Wazuh)	Khánh Hà	05/03 – 10/03
3	Thiết kế kiến trúc hệ thống và vẽ sơ đồ kiến trúc	Khánh Hà	08/03 – 18/03
4	Xây dựng mô hình Threat Modeling (STRIDE)	Khánh Hà	10/03 – 18/03
5	Triển khai OpenStack VM và networking cho hệ thống	Bảo Phước	19/03 – 25/03
6	Cài đặt Wazuh Manager và Agent trên các node	Bảo Phước	20/03 – 30/03
7	Triển khai ELK Stack (Elasticsearch, Logstash, Kibana)	Bảo Phước	25/03 – 02/04
8	Cấu hình index và pipeline log trong Elasticsearch	Khánh Hà	28/03 – 05/04
9	Viết custom Wazuh decoders và correlation rules	Khánh Hà	01/04 – 08/04
10	Triển khai Kafka và pipeline streaming logs	Bảo Phước	02/04 – 10/04
11	Xây dựng Kibana dashboards giám sát bảo mật	Bảo Phước	05/04 – 10/04
12	Deploy financial microservices trên K3s cluster	Bảo Phước	05/04 – 12/04
13	Phát triển Prometheus exporter cho business metrics	Bảo Phước	08/04 – 15/04
14	Thu thập dữ liệu training cho AI models	Khánh Hà	09/04 – 18/04
15	Xây dựng feature engineering và huấn luyện ML models	Khánh Hà	12/04 – 22/04
16	Phát triển RAG pipeline và vector database	Bảo Phước	18/04 – 28/04
17	Phát triển MCP servers và tích hợp AI engine	Bảo Phước	22/04 – 30/04
18	Triển khai TheHive và Cortex SOAR platform	Bảo Phước	30/04 – 05/05
19	Phát triển AI Playbook Engine	Khánh Hà	02/05 – 10/05
20	Phát triển Cortex Responders cho automation	Bảo Phước	05/05 – 12/05
21	Xây dựng workflow Human-in-the-Loop bằng n8n và Slack	Bảo Phước	06/05 – 13/05
22	Kiểm thử tích hợp toàn bộ hệ thống	Bảo Phước	10/05 – 18/05
23	Thiết kế và thực hiện các kịch bản tấn công kiểm thử	Khánh Hà	15/05 – 22/05

24	Phân tích kết quả và đo lường các metrics	Khánh Hà	20/05 – 26/05
25	Viết báo cáo đồ án và chuẩn bị slide	Khánh Hà	20/05 – 30/05
26	Chuẩn bị demo và video thuyết trình	Khánh Hà	25/05 – 30/05
Xác nhận của CBHD (Ký tên và ghi rõ họ tên)		TP. HCM, ngày 12 tháng 03 năm 2026 Sinh viên (Ký tên và ghi rõ họ tên) Sinh viên (Ký tên và ghi rõ họ tên)	